

CYPRUS REPUBLIC

File No.: 11.17.001.009.048

OFFICE OF THE COMMISSIONER FOR PERSONAL DATA PROTECTION

Complaint regarding access to a beneficiary's account of the General Health System (GeSY) by a physician
DECISION

Case Incidents

Positions of the Complainant

In the complaint dated March 22, 2021, the following was reported:

Based on the duties and powers conferred upon me by Article 57(1)(f) of Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (hereinafter referred to as the "Regulation"), I examined a complaint submitted to my Office on March 22, 2021, regarding access to the account of Mr. XXX (hereinafter referred to as the "Complainant") in the General Health System (GeSY) by Dr. XXX (hereinafter referred to as the "Respondent").

Based on the investigation, I found a violation of the Regulation by the Respondent and, therefore, I issue this Decision.

A.

2.

2.1. The Complainant was a patient/client of the Respondent around the year 2018, and on June 28, 2018, underwent surgery by the Respondent,

2.2. The Complainant posted a review and/or critique of the Respondent through the online platform Google Reviews,

2.3. In August 2020, the Respondent filed a lawsuit in the Limassol District Court against the Complainant, claiming general and special damages for defamatory publications,

2.4. The Complainant noticed, through his personal account on the beneficiary portal of the General Health System (GeSY), that the Respondent accessed the Complainant's beneficiary record on:

2.4.1. September 17, 2020, with the justification "The provider created a visit without a referral and had the consent of the beneficiary for access to their Medical Record," and

2.4.2. October 20, 2020, with the justification "The beneficiary was unconscious. The provider needed access to the Medical Record to provide emergency treatment,"

2.5. The Complainant stated that he had never visited and/or authorized the Respondent, with or without a referral, and that he was never unconscious and did not require treatment from the Respondent on those specific days.

The complaint included:

3.

3.1. A letter to the Commissioner of Supervision (GeSY), with a copy to my Office, which contained extensive reference to incidents and positions of the Complainant,

3.2. A screenshot from the GeSY beneficiary portal, which presented the accesses of the Respondent to the Complainant's beneficiary record, as referenced in paragraph 2.4 of this Decision.

4.

On March 31, 2021, the documents - evidence referred to in paragraph 3 of this Decision were resent, with a copy to my Office, via a letter from the Commissioner of Supervision (GeSY) to the Health Insurance Organization.

Positions of the Health Insurance Organization

5.

On April 21, May 17, June 28, 2021, and February 9, 2022, I sent letters to the Health Insurance Organization (hereinafter referred to as the "Organization") regarding the complaint, requesting to be informed about it and submitting clarifying questions.

6.

The Organization, in its letters to my Office dated May 24, September 14, 2021, February 8, February 17, and March 1, 2022, stated among other things the following:

6.1. Beneficiaries have the ability through the Beneficiary Portal to check the accesses of providers to their medical file as well as the relevant justifications. In case they find discrepancies, errors, omissions, or inaccuracies, they can proceed with a complaint, which the Organization undertakes to investigate and manage accordingly,

6.2. The Organization conducted an audit of the GeSY Information System. From the results of this audit for the period between May 2020 and April 2021, the Complainant's claim is confirmed - that the Respondent - provider with provider number DXXX, gained access to the medical data of the Complainant on the dates and with the justifications mentioned in paragraph 2.4 of this Decision,

6.3. An additional audit conducted by the Organization did not reveal any relationship between the Complainant and the Respondent within the GeSY framework during the relevant period. Specifically, on the dates of access, there was no active referral, nor was a relevant visit recorded, nor was a related request submitted by the Respondent. Also, the Respondent's access, at the material time, appeared to have occurred without the Complainant having visited the Respondent for health care services and/or without the Respondent having obtained the necessary authorizations and/or consent from the Complainant for access and/or without any indication of the need for emergency treatment.

6.4. The last access of the Respondent took place
XXX days before the termination of
his contract with the GHS, which was terminated on
XXX,

6.5. From the moment the provider gained
access to the medical file of the
Complainant, he had the ability to proceed
with acts of processing the
personal data of the Complainant
(e.g., viewing, copying, downloading),

6.6. XXX,

6.7. XXX:

6.7.1. XXX.

6.7.2. XXX,

6.8. The claims made by the doctor, through
his lawyers, regarding perpetual
consent and/or that the Complainant
never expressly withdrew any
consent of his were not accepted by the
Organization. As mentioned, according to
the Regulation, the legal basis for the
processing of personal data of a
beneficiary by a provider is primarily the
execution of the contract for the provision
of healthcare services, and since this concerns
health data, their processing is prohibited
unless one of the exceptions of Article 9 of

the Regulation is met, which in this case, the processing is lawful if it is necessary for medical diagnosis, provision of healthcare, or treatment under a contract.

6.9. XXX.

7.

7.1. A table with the results of the audit, showing which healthcare service providers, who are contracted with the Organization, had access to the electronic file of the Complainant, between May 2020 and April 2021,

7.2. The personal data protection policy of the GHS online portal.

The Organization submitted to my Office:

Positions of the Respondent

On June 17, 2022, I received from the lawyer of the Respondent, a letter dated

On May 30, 2022, I sent a letter to the Respondent, requesting that

8.

specific questions be answered.

9.

On June 16, 2022, with the following positions:

9.1.

The Complainant on June 28, 2018,

9.2. The patient-doctor relationship continued during the recovery of the Complainant, without it being interrupted until the date of the Respondent's response to my Office, while the Complainant never expressly withdrew any consent of his,

the Respondent, following written consent and agreement, operated on the

3

it is confirmed that the Respondent had access to the medical record of the Complainant

9.3. on September 17, 2020, with the justification "The provider created a visit without a referral and had the consent of the beneficiary for access to their Medical Record," and on October 20, 2020 with the justification "The beneficiary was unconscious. The provider needed access to the Medical Record to provide emergency treatment,"

9.4. On September 17, 2020, the Respondent received a phone call from the brother of the

Complainant, who informed the Respondent that the health condition of the Complainant had worsened and was planning surgery at a medical center abroad. The Respondent, out of genuine concern for the Complainant, connected to the system to be informed about the state of his health,

9.5. On October 20, 2020, the Respondent had received a patient who informed him that the Complainant had referred him to the Respondent. The Respondent, out of genuine concern for the Complainant and since he had no new communication with the brother, connected to the system to be informed about the state of the Complainant's health,

9.6. The justifications recorded in the system were for formal reasons, as there was no specific justification for why the Respondent wished to access the medical record of the Complainant,

9.7. The Respondent believed that the doctor-patient relationship continued, especially after the initiative of the Complainant to refer another patient to him,

9.8. Access to the medical file was brief, without the Respondent taking any further action and without the details of the Complainant and/or his medical file being subject to any processing and/or alteration,

9.9. The lawyers of the Complainant sent the Respondent a letter, dated July 7, 2020, in response to a letter from the Respondent dated June 3, 2020, regarding the cessation of the defamation of the Respondent by the Complainant, while the Complainant filed a lawsuit for alleged medical negligence against the Respondent, on October 29, 2021. The above fact, in combination with the time that elapsed from the date of the letter from the Complainant's lawyers until the Respondent's access to the Complainant's file, proves that it is not true that the motives of the Respondent were ulterior and that they aimed at preparing him in relation to a potential lawsuit against him. Also, as mentioned, none of the data in the medical file could have any usefulness to the Respondent in the event of legal proceedings.

10.
the positions of the Respondent, as well as clarifying

questions.

11. The lawyer of the Complainant, in a letter dated August 8, 2022,

informed my Office of the following:

On July 18, 2022, I sent a letter to the Complainant, submitting

Positions of the Complainant.

****Positions of the Respondent****

On October 10, 2022, I sent a letter to the Respondent, submitting the following:

11.1. Beyond the fact that the Respondent operated on the Complainant on June 28, 2018, the other claims made by the Respondent, which were submitted to the Complainant via a letter from my Office dated July 18, 2022, are not accepted.

11.2. The last provision of services by the Respondent to the Complainant was on the date of the operation.

11.3. The brother of the Complainant never contacted the Respondent on the aforementioned date.

11.4. The Complainant never referred another patient to the Respondent.

12. Positions of the Complainant and I posed clarifying questions.

13. The lawyer of the Respondent, in a letter dated November 10, 2022, stated to my Office the following:

13.1. The last provision of services by the Respondent to the Complainant was not on June 28, 2018, that is, the date on which the operation was performed, as approximately five scheduled visits of the Complainant to the Respondent's office followed postoperatively. During a visit of the Complainant on August 4, 2018, the Complainant was accompanied by his brother to undergo a neurosurgical examination.

13.2. Furthermore, there is recorded electronic communication from the Complainant to the Respondent's email, which concerns documents for sick leave and other documents related to the surgery he underwent. Specifically, the last email from the Complainant to the Respondent was on January 9, 2020.

13.3. There is also, as mentioned, a telephone communication with the Complainant, which, however, is not recorded.

On February 21, 2023, I sent the Respondent a prima facie Decision,

14. after determining that there is a prima facie violation of Article 9(2)(h) of the Regulation, because the processing actions undertaken, namely the accesses to the Complainant's beneficiary file, were not based on the relevant legal basis.

14.1. Also, before making a Decision regarding the possible imposition of an administrative fine, the Respondent was invited to submit the reasons and circumstances that should be taken into account in the context and for the purposes of imposing an administrative sanction, pursuant to Article 58(2) of the Regulation.

15. On April 2023, the following was stated:

15.1. Disagreement is expressed with the findings of my prima facie Decision dated February 21, 2023, as it is considered that there was continuous consent from the Complainant, which was never expressly withdrawn. It is also stated that the Complainant "abuses you as a vehicle to achieve his own purposes."

15.2. The content of the letters dated June 16, 2022, and November 12, 2022, is reiterated. I note that, as it appears, the Respondent's lawyer refers in his letter dated June 16, 2022, which was submitted to my Office on June 17, 2022, and in his letter dated November 10, 2022, respectively.

15.3. The prior life of the Respondent, the individual incidents, and the totality of the facts, such as the absence of processing, do not justify, as stated, "the imposition of any penalty other than (possibly) just a reprimand."

15.4. Furthermore, the individual incident and/or its duration, the surrounding circumstances, and the sincere and honest motives of the Respondent, as stated, "underscore the fact that there is no issue to be 'corrected' and there is no question of any repetition."

15.5. XXX

15.6. Due to the above, any other penalty beyond a reprimand is considered disproportionate, unjust, and would not serve any deterrent purpose or the purposes and true meaning of the Regulation.

****B.****

16. According to Article 4 of the Regulation, personal data is interpreted as "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, psychological, economic, cultural, or social identity of that natural person."

17. As health data, as provided in the same article of the Regulation, are described as "personal data which relate to the physical or mental health of a natural person, including the provision of health care services, and which reveal information about the health status of that person."

18. As the data controller, Article 4 of the Regulation defines "the natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union law or the law of a Member State, the controller or the specific criteria for its designation may be provided for by Union law or the law of a Member State."

****Legal Aspect****

19. As consent, Article 4 of the Regulation defines "any indication of will, free, specific, explicit, and fully informed, by which the data subject indicates agreement, by statement or by a clear affirmative action, for the personal data concerning them to be processed."

20. Regarding the processing of special categories of personal data, Article 9 of the Regulation provides the following:

Paragraph 1 does not apply in the following cases:

"1. The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, as well as the processing of genetic data, biometric data for the purpose of uniquely identifying a person, data concerning health, or data concerning the sexual life of an individual or their sexual orientation is prohibited.

2. The data subject has given explicit consent for:

- a) the processing of such personal data for one or more specific purposes, unless Union or Member State law provides that the prohibition referred to in paragraph 1 cannot be lifted by the data subject,
- b) the processing is necessary for the performance of obligations and the exercise of specific rights of the data controller or the data subject in the field of employment law and social security and social protection law, provided that it is permitted by Union or Member State law or by collective agreement in accordance with national law, providing appropriate safeguards for the fundamental rights and interests of the data subject,
- c) the processing is necessary to protect the vital interests of the data subject or another natural person, if the data subject is physically or legally incapable of giving consent,
- d) the processing is carried out, with appropriate safeguards, in the course of the legitimate activities of a foundation, association, or other not-for-profit body with a political, philosophical, religious, or trade union aim and provided that the processing relates solely to the members or former members of the

body or to persons who have regular contact with it in relation to its purposes and that the personal data are not disclosed outside that body without the consent of the data subjects,

- e) the data has been made public by the data subject,
- f) the processing is necessary for the establishment, exercise, or defense of legal claims or whenever courts are acting in their judicial capacity,
- g) the processing is necessary for reasons of substantial public interest, based on Union or Member State law, which is proportionate to the aim pursued, respects the essence of the right to data protection, and provides for appropriate and specific measures to safeguard the fundamental rights and interests of the data subject,
- h) the processing concerns personal data which are necessary for the purposes of preventive or occupational medicine, for the assessment of the working capacity of the employee, for medical diagnosis, for the provision of health or social care or treatment, or for the management of health or social care systems and services based on Union law or the law of a Member State or pursuant to a contract with a health professional and subject to the conditions and safeguards referred to in paragraph 3,
- i) the processing is necessary for reasons of public interest in the area of public health, such as protecting against serious cross-border threats to health or ensuring high standards of quality and safety of health care and of medicinal products or medical devices, based on Union law or the law of a Member State, which provides for appropriate and specific measures to protect the rights and freedoms of the data subject, in particular the professional secrecy, or
- j) the processing is necessary for archiving purposes in the public interest, for scientific or historical research purposes, or for statistical purposes in accordance with Article 89 paragraph 1 based on Union law or the law of a Member State, which are proportionate to the aim pursued, respect the essence of the right to data protection, and provide for appropriate safeguards for the fundamental rights and interests of the data subject."

****Substance of the Right to Data Protection****

and appropriately and specifically provides measures for the safeguarding of the fundamental rights and interests of the data subject.

3. The personal data referred to in paragraph 1 may be processed for the purposes provided in paragraph 2, point (h), when such data is processed by or under the responsibility of a professional who is subject to the obligation of professional secrecy under Union law or the law of a Member State or under rules established by competent national authorities or by another person who is also under an obligation of confidentiality under Union law or the law of a Member State or under rules established by competent national authorities.

4. Member States may maintain or establish further conditions, including restrictions, regarding the processing of genetic data, biometric data, or data concerning health.

21. Pursuant to Article 57, paragraph 1, point (f) of the Regulation, the Commissioner for Personal Data Protection has the duty to:

"handle complaints submitted by the data subject or by a body or organization or association in accordance with Article 80 and investigate, to the extent appropriate, the subject matter of the complaint and inform the complainant of the progress and outcome of the investigation within a reasonable time, particularly if further investigation or coordination with another supervisory authority is required."

22. Regarding the submission of a complaint to the Supervisory Authority, Article 77 of the Regulation provides that:

"Subject to any other administrative or judicial remedies, every data subject has the right to lodge a complaint with a supervisory authority, in particular in the Member State of their habitual residence or place of work or the place of the alleged infringement, if the data subject considers that the processing of personal data concerning them infringes this Regulation."

23. Pursuant to Article 58, paragraph 2, of the Regulation, the Commissioner for Personal Data

Protection has the following corrective powers:

to order the data controller to notify the breach

"a) to issue warnings to the data controller or the processor that intended processing operations are likely to infringe provisions of this Regulation,

b) to issue reprimands to the data controller or the processor when processing operations have infringed provisions of this Regulation,

c) to order the data controller or the processor to comply with the requests of the data subject to exercise their rights under this Regulation,

d) to order the data controller or the processor to bring processing operations into compliance with the provisions of this Regulation, if necessary, in a specific manner and within a specified time limit,

e) to impose a temporary or definitive limitation, including a ban on processing,

f) to order rectification or erasure of personal data or restriction of processing pursuant to Articles 16, 17, and 18 and to order notification of such actions to recipients to whom the personal data have been disclosed pursuant to Article 17, paragraph 2, and Article 19,

g) to withdraw a certification or to order the certification body to withdraw a certificate issued in accordance with Articles 42 and 43 or to order the certification body not to issue a certification, if the certification requirements are not met or are no longer met,

h) to impose administrative fines pursuant to Article 83, in addition to or instead of the measures referred to in this paragraph, depending on the circumstances of each individual case,

i) to impose a temporary or definitive limitation, including the suspension of data flows to a third country or to an international organization."

Regarding the general terms for the imposition of administrative fines, Article 83, paragraph 2, of the Regulation provides the following:

"Administrative fines, depending on the circumstances of each individual case, may be imposed in addition to or instead of the measures referred to in Article 58, paragraph 2, points (a) to (h) and in Article 58, paragraph 2, point (i). In deciding whether to impose an administrative fine and regarding the amount of the administrative fine for each individual case, the following shall be duly taken into account:"

the adherence to approved codes of conduct in accordance with Article 40 or

the degree of cooperation with the supervisory authority for the rectification of

the categories of personal data affected by any relevant previous violations of the data controller or the nature, gravity, and duration of the violation, taking into account the

a) nature, scope, or purpose of the relevant processing, as well as the number of data subjects affected by the violation and the degree of harm suffered,

the intent or negligence that caused the violation,

b)

c) any actions taken by the data controller or the processor to mitigate the damage suffered by the data subjects,

d) the degree of responsibility of the data controller or the processor, taking into account the technical and organizational measures implemented under Articles 25 and 32,

e) of the processor,

f) the violation and the limitation of its potential adverse effects,

g)

the violation,

h) the manner in which the supervisory authority was informed of the violation, particularly whether and to what extent the data controller or the processor notified the violation,

i) in the event that measures referred to in Article 58(2) were previously ordered against the involved data controller or processor regarding the same subject, compliance with those measures,

j) approved certification mechanisms in accordance with Article 42 and

k) any other aggravating or mitigating factor arising from the circumstances of the specific case, such as the financial benefits gained or damages avoided, directly or indirectly, from the violation.

3. In the event that the data controller or the processor, for the same or related processing operations, violates several provisions of this regulation, the total amount of the administrative fine shall not exceed the amount set for the most serious violation.

4. Violations of the following provisions shall incur, according to paragraph 2, administrative fines of up to 10,000,000 EUR or, in the case of enterprises, up to 2% of the total global annual turnover of the previous financial year, whichever is higher:

- a) the obligations of the data controller and the processor according to Articles 8, 11, 25 to 39, and 42 and 43, the obligations of the certification body according to Articles 42 and 43,
- b)
- c) the obligations of the monitoring body according to Article 41 paragraph 4.

5. Violations of the following provisions shall incur, according to paragraph 2, administrative fines of up to 20,000,000 EUR or, in the case of enterprises, up to 4% of the total global annual turnover of the previous financial year, whichever is higher:

the transfer of personal data to a recipient in a third country

the rights of data subjects according to Articles 12

the basic principles for processing, including the conditions that

a) apply for approval, according to Articles 5, 6, 7, and 9,

b) up to 22,

c) or to an international organization according to Articles 44 to 49,

d) any provisions established under Chapter IX,

e) non-compliance with an order or with a temporary or permanent restriction of processing or with the suspension of data circulation imposed by the supervisory authority under Article 58 paragraph 2 or failure to provide access in violation of Article 58 paragraph 1.

Any obligations according to the law of the member state

According to Regulation 16(2) of the General System Regulations (Special Physicians)

25.

of 2019, it is provided that:

"The specialized physician, for the purpose of providing healthcare services, has access to the beneficiary's file in accordance with the provisions of the Law and the provisions of the Regulations, internal regulations, and Decisions issued under it."

25.1. Regarding the Information System of the Organization, Article 32C of the General Health System Law of 2001, Law 89(I)/2001, provides the following:

"(1) Healthcare service providers are obliged to use the information system for the issuance of referrals and prescriptions, the submission of claims for remuneration, the management of the list of beneficiaries, and any other actions and/or processes that are determined in this Law and in the Regulations, internal regulations, and Decisions issued under it:

Provided that the actions and/or processes referred to in paragraph (1) are carried out only through the information system, unless the Organization specifies otherwise.

(2) For the purposes of this Law as well as any civil or criminal proceedings, the Organization provides the person entitled to use the information system with security codes, which shall serve as a substitute for handwritten signatures that would appear on any documents if..." submitted without the use of an information system.

(3) For the use of the information system, the Organization issues a document of terms and conditions which includes the terms and conditions that must be adhered to by any person using the information system.

(4) The user of the information system undertakes to fully comply with the security rules as described in the terms and conditions of the information system, as well as with the provisions of the Personal

Data Processing (Protection of the Individual) Law.

(5) The beneficiaries have the right to use the information system, provided that they comply with the provisions of paragraphs (2), (3), and (4):

It is understood that the generality of the provisions of Articles 54, 54A, and 54B is not affected.

Reasoning

G.

26. XXX.

27. XXX.

In the case under investigation, there is an admission by the Respondent that he had access to the beneficiary file of the Complainant on the dates and for the reasons mentioned in paragraph 2.4 of this document.

28. These accesses by the Respondent were carried out for the purpose or purposes that he himself has determined; therefore, for the specific processing acts, he is considered a data controller, with all the obligations arising from the Regulation.

29. Even if, as the Respondent stated, his access to the Complainant's file was brief and he did not take any further action and without any processing and/or alteration of the Complainant's data and/or his medical file, the Respondent's accesses to the beneficiary file of the Complainant constitute acts of processing. This conclusion holds even if the Respondent did not view, copy, or download the Complainant's data, that is, in acts in which he had the ability to engage, as noted by the Organization. Moreover, the fact that the Respondent did not make a request to the Organization does not negate this conclusion.

30. The surgical procedure to which the Complainant was subjected took place before the implementation of the General Health System (GeSY). It follows, therefore, that the doctor-patient relationship during the surgical procedure, specifically between the Respondent and the Complainant respectively, was not governed by GeSY.

31. The Complainant stated that the last service he received from the Respondent was on the day of the surgery. However, the Respondent stated that there were approximately five post-operative visits to the office, referencing a visit by the Complainant on August 4, 2018, without clarifying the last visit of the Complainant. I therefore have before me conflicting positions regarding the last visit of the Complainant to the Respondent.

32. In any case, however, as the Organization stated to my Office, in the audit it conducted for a period that includes the dates of the Respondent's access to the beneficiary file of the Complainant, no relationship was demonstrated between the Respondent and the Complainant.

33. As the Respondent stated, there was an unrecorded telephone communication with the Complainant, without clarifying when this took place, and that the last electronic message from the Complainant to the Respondent was on January 9, 2020. Considering that the accesses made by the Respondent occurred several months later, it was not proven that there was any relationship between the Complainant and the Respondent that would justify and legitimize the Respondent's accesses to the beneficiary file of the Complainant.

34. Considering that the beneficiary file of the Complainant contains and includes data related to health, therefore special categories of personal data, the processing of this data is prohibited unless one of the cases of Article 9, paragraph 2 of the Regulation applies.

35. Regarding the access of a doctor to the medical file of a GeSY beneficiary, the legal basis is Article 9(2)(h) of the Regulation. Specifically, processing is not prohibited when:

“the processing is necessary for the purposes of preventive or occupational medicine, the assessment of the employee's working capacity, medical diagnosis, the provision of health or social care or

treatment, or the management of health and social systems and services based on the
**of Union law or the law of the Member State or under a contract with a healthcare professional and
subject to the conditions and guarantees referred to in paragraph 3**

37. Considering that there was a prior relationship between the Complainant and the Respondent and that the Respondent had the necessary information to access the Complainant's beneficiary file, accesses to the Complainant's file would be justified if they were in accordance with the relevant regulations of the Organization, for the purposes of Article 9(2)(h) of the Regulation.

38. Even if it were true that the Complainant's brother contacted the Respondent by phone and referred to the Complainant's health condition, and that the Respondent, out of genuine concern for the Complainant, connected to the system to be informed about the Complainant's health status, the Respondent's access to the Complainant's beneficiary file cannot be framed by any case of paragraph 2 of Article 9 of the Regulation, since at the essential time the Complainant was not receiving services from the Respondent.

39. The above conclusion also applies in the event that the Complainant indeed referred another patient to the Respondent. However, in no case does it hold that the doctor-patient relationship continues to exist if the patient refers another patient to a doctor, a consideration made by the Respondent, as mentioned to my Office.

40. The legal basis for access to the beneficiary file cannot be based on Article 9(2)(a) of the Regulation, namely the explicit consent of the Complainant. Moreover, any patient does not expect that a doctor who had provided them with healthcare services in the past and before the implementation of the General Health System (GeSY) would process their data within the framework of GeSY, without there being a doctor-patient relationship at that given moment.

41. Therefore, the fact that, as stated by the Respondent, the Complainant never expressly withdrew any consent and that there was continuous consent has no validity. The term "continuous consent" is, moreover, contrary to the definition of consent, as contained in Article 4 of the Regulation, since consent must be "specific."

42. Furthermore, as stated by the Respondent, none of the data in the medical file could have any usefulness to the Respondent in the event of legal proceedings. Even if this position holds, it does not negate the fact that the processing actions undertaken by the Respondent should be based on a legal basis as provided in Article 9(2) of the Regulation.

43. The Respondent's lawyer refers to the absence of processing. I remind that access to a patient's beneficiary file, which requires the use/registration of the identity card number and the date of birth, constitutes processing of personal data.

44. Regarding the complaint under investigation, the prior life of the Respondent, which is invoked by their lawyer, cannot be taken as a mitigating factor, which I do not examine, but in no case do I dispute.

45. Furthermore, even if the sincere and honest motives referred to by the Respondent's lawyer are valid, they cannot legally frame the processing actions undertaken by the Respondent. They also cannot constitute a mitigating factor, since while the Respondent claims to have gained access out of genuine interest, following a phone call from the Complainant's brother and after referring another patient, the Complainant denies the above facts.

46. The doctor's access to the Complainant's beneficiary file cannot be considered an isolated incident, since the Respondent had access to the said file twice. I acknowledge the fact that no similar complaint had been previously submitted, nor subsequently, against the Respondent, a fact which in no case diminishes the violation of the Complainant's personal data. Therefore, the above cannot be construed as a mitigating factor.

47. Nor can the duration of the incident, which the Respondent's lawyer invokes, be considered a mitigating factor, especially since more than one month elapsed between the Respondent's accesses.

48. The Respondent's lawyer refers to surrounding circumstances. The surrounding circumstances have not created in the incident under investigation suitable conditions so that the actions undertaken by the Respondent are enveloped in legality. Therefore, the surrounding circumstances cannot be considered a mitigating factor.

49. As the Respondent's lawyer states, there is no issue of any repetition. Even if this is true, it does not negate the violation committed by the Respondent. Nor does the assertion that there is no issue for "correction" hold, since in any case, the Complainant's data were violated. However, I assess as
Conclusion

A mitigating factor is the fact that the Subject is no longer contracted with the GeSY and, therefore, cannot regain access to the account of any beneficiary of the GeSY.

50. Additionally, in assessing the penalty, I take into account the fact that XXX.

51. The statement of the Subject's lawyer that the Complainant "abuses you as a vehicle to achieve his own purposes" is an affront to my Office and to the institution that I am mandated to serve. I emphasize that I evaluate impartially the evidence presented before my Office concerning the processing of personal data arising from the complaint under investigation. I will not examine, nor does it concern me, whether other purposes are concealed behind the specific complaint.

52. I also find the term "abusive" inappropriate, as under Article 77 of the Regulation, the data subject has the right to submit a complaint to a Supervisory Authority, which complaint is handled by the Supervisory Authority under Article 57(1)(f) of the Regulation.

D.

53. Taking into account all of the above elements, as they have been presented, and based on the powers granted to me under Article 57(1)(f) of the Regulation, I find that there is a violation by the Subject of Article 9(2)(h) of the Regulation (EU) 2016/679, because the processing activities carried out by him, namely the accesses to the file of the Complainant's beneficiary, lacked legality, as they were not based on the relevant legal basis.

54. Based on the provisions of Article 83 of the Regulation, regarding the conditions for imposing administrative fines, to the extent that they apply to the specific case, in assessing the administrative fine, I took into account the following aggravating (a) – (b) and mitigating (c) – (g) factors:

(a) data,

(b) Complainant twice,

(c)

(d)

(e)

(f) complaint,

(g) the fact that the Subject gained access to the file of the beneficiary, the acquisition of access by the Subject to a file that includes sensitive

the cooperation of the Subject with my Office in the context of the investigation of the fact that the Subject is no longer contracted with the GeSY, the absence of a previous Decision against the Subject. the incident concerned a data subject, XXX,

the above-mentioned mitigating and aggravating factors, the applicable legislative basis regarding the prescribed administrative sanctions all circumstances and factors presented by the Complainant and the Subject

55. After taking into account and considering:

(a) the provisions of Article 58(2) and Article 83 of the Regulation,

(b) before me based on all existing correspondence,

(c)

I find that, under the circumstances, the imposition of an administrative fine is not justified.

56. Nevertheless, having regard to the aforementioned facts, the legal aspect on which this Decision is based, and the analysis as explained above, and exercising the powers granted to me by Article 58(2)(b) of the Regulation,

I have decided

in my judgment and in accordance with the above provisions, to issue a reprimand to Dr. XXX for the violation of Article 9(2)(h) of the Regulation (EU) 2016/679.

****Peace Loizidou Nikolaidou****

****Commissioner for the Protection of Personal Data****

****December 5, 2023****